# TÀI LIỆU HỌC TẬP

# CƠ SỞ HẠ TẦNG KHÓA CÔNG KHAI (PKI) & CHUYỂN DỊCH MẬT MÃ HẬU LƯỢNG TỬ (PQC)

**Mã học phần:** ATHK 512 · **Khóa đào tạo:** Cao học An toàn Thông tin (CHAT4P)
**Học kỳ:** HK261 · **Năm học:** 2026 – 2027
**Cơ sở đào tạo:** Khoa An toàn Thông tin — Học viện Kỹ thuật Mật mã (Phân hiệu TP.HCM)
**Đơn vị phối hợp chuyên môn:** Khoa Khoa học & Kỹ thuật Máy tính, Trường Đại học Bách khoa — ĐHQG TP.HCM

---

### THÔNG TIN ĐỘI NGŨ GIẢNG DẠY & HỖ TRỢ HỌC THUẬT


- **Chủ biên & Giảng viên phụ trách:**
  **Nguyễn An Khương**
  *Đơn vị công tác:* Khoa Khoa học & Kỹ thuật Máy tính, Trường Đại học Bách khoa — ĐHQG TP.HCM
  *Mã định danh học thuật toàn cầu:* ORCID: 0000-0002-9910-6387
  *Email công vụ:* `nakhuong@gmail.com` / `nakhuong@hcmut.edu.vn`
- **Trợ giảng học phần (Teaching Assistant):**
  **Nguyễn Hữu Hoàng Huy**
  *Hồ sơ chuyên môn:* LinkedIn Profile
  *GitHub:* `@HuyLHP` (Quyền quản trị kỹ thuật: Collaborator `write`)


---

### BẢN QUYỀN VÀ GIẤY PHÉP PHÁT HÀNH


- **Bản quyền Nội dung & Học liệu:** Bản quyền thuộc về Giảng viên **Nguyễn An Khương**. Tác phẩm này được phát hành dưới Giấy phép Quốc tế Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 (CC BY-NC-ND 4.0). Người học được phép sao chép, phân phối tài liệu cho mục đích học tập cá nhân phi thương mại, không được phép chỉnh sửa hoặc cắt ghép nội dung khi chưa có văn bản chấp thuận của tác giả.
- **Bản quyền Mã nguồn & Thực nghiệm:** Toàn bộ mã nguồn, kịch bản tự động hóa, cấu hình container Docker và test suites trong học liệu được phát hành theo Giấy phép Nguồn mở MIT (MIT License).


---

## LỜI NÓI ĐẦU

Hạ tầng Khóa Công khai (Public Key Infrastructure - PKI) từ lâu đã trở thành "xương sống vô hình" bảo đảm tính bảo mật, toàn vẹn, xác thực và chống chối bỏ cho toàn bộ thế giới số hiện đại. Từ giao thức bắt tay TLS bảo vệ hàng tỷ phiên duyệt web an toàn mỗi ngày, chữ ký số trên các chứng từ tài chính - ngân hàng, đến các định danh thiết bị IoT và cơ chế khởi động an toàn (Secure Boot) trong hệ điều hành máy tính — tất cả đều vận hành dựa trên các nguyên lý cốt lõi của PKI.

Tuy nhiên, kỷ nguyên số đang bước vào một khúc quanh lịch sử với hai chuyển biến mang tính cách mạng: 1. **Kiến trúc Zero Trust & Điện toán Đám mây Phân tán:** Mô hình chu vi mạng truyền thống bị xóa bỏ hoàn toàn. Các hệ thống hiện đại đòi hỏi hàng triệu kết nối mTLS giữa các microservices được

mã hóa với chứng chỉ có thời hạn sống biểu kiến (ephemeral certificates tính bằng giờ hoặc phút), kéo theo yêu cầu tự động hóa tuyệt đối thông qua giao thức ACME (RFC 8555) và kiểm định tuân thủ tự động (ZLint). 2. **Nguy cơ Hiện hữu từ Điện toán Lượng tử (Post-Quantum Transition):** Thuật toán lượng tử Shor đã chứng minh khả năng bẻ gãy hoàn toàn các hệ mật mã khóa công khai kinh điển dựa trên bài toán phân tích thừa số nguyên tố (RSA) và logarit rời rạc (DSA, ECDSA, ECDH) trong thời gian đa thức. Tháng 8/2024, Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) đã chính thức ban hành bộ tiêu chuẩn FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) và FIPS 205 (SLH-DSA), mở ra một cuộc đại di chuyển mật mã (cryptographic migration) quy mô toàn cầu chưa từng có trong lịch sử nhân loại.

Bộ **Tài liệu học tập: Cơ sở Hạ tầng Khóa công khai & Mật mã Hậu lượng tử** này được biên soạn dành riêng cho học viên cao học ngành An toàn Thông tin (CHAT4P) nhằm trang bị một góc nhìn sâu sắc, toàn diện và hiện đại: kết hợp chặt chẽ giữa **nền tảng toán học hàn lâm chuẩn mực**, **chuẩn giao thức kỹ thuật quốc tế (IETF RFCs, CA/B Forum, NIST FIPS)** và **năng lực thực chiến công nghiệp (DevSecOps, Docker, OpenSSL 3.5, liboqs, HSM)**.

Tài liệu được kết cấu thành 8 chương chuyên sâu kèm theo hệ thống phụ lục thực nghiệm phong phú, đóng vai trò là kim chỉ nam xuyên suốt 9 buổi học lý thuyết, thực hành phòng lab và 5 đề tài đồ án chuyên đề lớn của học phần.

---

## MỤC LỤC TỔNG QUAN


- **Chương 1:** Nền Tảng Lý Thuyết Số & Cơ Sở Toán Học Mật Mã Khóa Công Khai
- **Chương 2:** Cấu Trúc Dữ Liệu Chứng Chỉ X.509 v3 & Quy Cách Mã Hóa ASN.1 DER
- **Chương 3:** Kiến Trúc Phân Tầng CA, Vòng Đời Khóa & Quy Chế CP/CPS (RFC 3647)
- **Chương 4:** Thuật Toán Xác Thực Đường Dẫn Tin Cậy & Cơ Chế Thu Hồi Chứng Chỉ
- **Chương 5:** Giao Thức Quản Trị Tự Động ACME (RFC 8555) & Hạ Tầng Zero Trust PKI
- **Chương 6:** Các Kịch Bản Tấn Công Hạ Tầng PKI & Chiến Lược Phòng Thủ Toàn Diện
- **Chương 7:** Chuyển Dịch Hệ Thống Sang Mật Mã Hậu Lượng Tử (PQC Migration)
- **Chương 8:** Khung Pháp Lý, Quy Chuẩn Kỹ Thuật & Hạ Tầng Chữ Ký Số Quốc Gia
- **Phụ lục A:** Cẩm Nang 50 Lệnh OpenSSL 3.5 Thực Chiến Cho Chuyên Gia ATTT
- **Phụ lục B:** Bộ Công Cụ Python Cryptography Phân Tích & Kiểm Định Chứng Chỉ
- **Phụ lục C:** Danh Mục Tài Liệu Tham Khảo Hàn Lâm & Khóa Học Quốc Tế (OCW)


---

# CHƯƠNG 1: NỀN TẢNG LÝ THUYẾT SỐ & CƠ SỞ TOÁN HỌC MẬT MÃ KHÓA CÔNG KHAI

## 1.1. Cấu Trúc Đại Số Trừu Tượng & Các Phép Toán Số Học

Mật mã khóa công khai không thể tồn tại nếu thiếu nền tảng vững chắc của đại số trừu tượng. Thay vì hoạt động trên tập số thực liên tục $\mathbb{R}$, mật mã học hiện đại vận hành trên các cấu trúc rời rạc hữu hạn nhằm bảo đảm tính chính xác tuyệt đối và ngăn chặn triệt để hiện tượng sai số làm tròn số học.

### 1.1.1. Nhóm (Groups), Vành (Rings) và Trường Hữu Hạn (Finite Fields)

1. **Nhóm (Group):** Một tập hợp $G$ cùng với phép toán hai ngôi $\star$ được gọi là một nhóm $(G, \star)$ nếu thỏa mãn 4 tiên đề:
    - **Tính đóng (Closure):** $\forall a, b \in G \implies a \star b \in G$.

- **Tính kết hợp (Associativity):** $\forall a, b, c \in G \implies (a \star b) \star c = a \star (b \star c)$.
- **Phần tử trung hòa (Identity):** $\exists e \in G, \forall a \in G \implies a \star e = e \star a = a$.
- **Phần tử nghịch đảo (Inverse):** $\forall a \in G, \exists a^{-1} \in G \implies a \star a^{-1} = a^{-1} \star a = e$.
- Nếu $a \star b = b \star a$, nhóm được gọi là **nhóm giao hoán (nhóm Abel)**.

2. **Vành (Ring):** Một tập hợp $R$ cùng hai phép toán cộng $(+)$ và nhân $(\cdot)$ được gọi là một vành nếu $(R, +)$ là một nhóm Abel, phép nhân có tính kết hợp và phân phối đối với phép cộng. Vành số dư $\mathbb{Z}_n = \{0, 1, \dots, n-1\}$ là vành cơ bản của hệ mật RSA.
3. **Trường (Field):** Một vành giao hoán có đơn vị mà trong đó mọi phần tử khác 0 đều khả nghịch dưới phép nhân. Trường hữu hạn Galois $\mathbb{F}_q$ chỉ tồn tại khi số phần tử $q = p^m$ (với $p$ là số nguyên tố và $m \geq 1$):
   - Khi $m = 1$, ta có trường số nguyên tố $\mathbb{F}_p = \mathbb{Z}_p$, nơi các phép toán modulo $p$ diễn ra.
   - Khi $m > 1$, ta có trường mở rộng $\mathbb{F}_{2^m}$, đặc biệt quan trọng trong phần cứng mật mã vi mạch.

#### 1.1.2. Các Định Lý Số Học Cốt Lõi

- **Bổ đề Bézout & Thuật toán Euclid mở rộng:** Với hai số nguyên $a, b$, luôn tồn tại hai số nguyên $x, y$ sao cho:
$$a \cdot x + b \cdot y = \gcd(a, b)$$
Khi $\gcd(a, n) = 1$, ta có $a \cdot x \equiv 1 \pmod{n}$, tức $x = a^{-1} \pmod{n}$. Thuật toán Euclid mở rộng tính toán phần tử nghịch đảo này trong độ phức tạp thời gian cực nhanh $O(\log n)$.
- **Định lý Fermat nhỏ & Định lý Euler:**
  - Nếu $p$ nguyên tố và $\gcd(a, p) = 1$, thì $a^{p-1} \equiv 1 \pmod{p}$.
  - Tổng quát hóa bởi Leonhard Euler: Với số nguyên dương $n$, hàm phi Euler $\phi(n)$ đếm số lượng các số nguyên dương nhỏ hơn $n$ và nguyên tố cùng nhau với $n$. Nếu $n = p \cdot q$ ($p, q$ nguyên tố), thì:
  $$\phi(n) = (p-1)(q-1)$$
  - Khi đó, với mọi $a$ nguyên tố cùng nhau với $n$:
  $$a^{\phi(n)} \equiv 1 \pmod{n}$$
- **Định lý Phần dư Trung Hoa (Chinese Remainder Theorem - CRT):** Cho các số nguyên dương $m_1, m_2, \dots, m_k$ đôi một nguyên tố cùng nhau. Hệ phương trình đồng dư:
$$x \equiv a_i \pmod{m_i} \quad (i = 1, \dots, k)$$
luôn có nghiệm duy nhất modulo $M = \prod_{i=1}^{k} m_i$. Trong cài đặt thực tế của RSA, kỹ thuật RSA-CRT phân rã phép tính lũy thừa trên module 2048-bit thành hai phép tính trên hai module $p$ và $q$ 1024-bit, giúp tăng tốc độ giải mã và ký số lên **4 lần**.

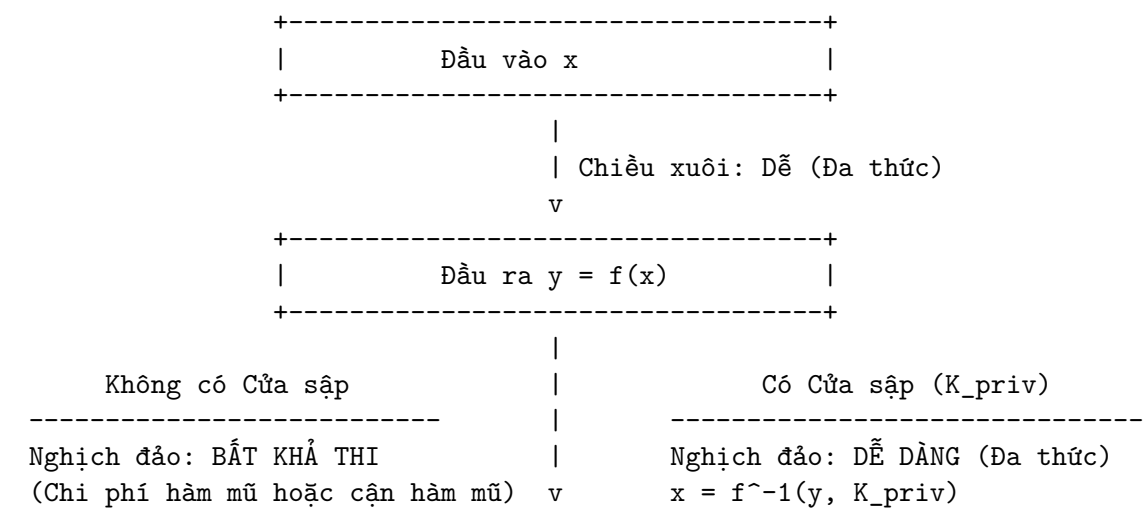
---

### 1.2. Khái Niệm Hàm Một Chiều & Cửa Sập (Trapdoor One-Way Functions)

Mọi hệ thống mật mã khóa công khai đều được xây dựng trên nền tảng của **Hàm một chiều có cửa sập (Trapdoor One-Way Function - TOWF)**:

$$f : X \to Y$$

Hàm $f$ phải thỏa mãn ba đặc trưng toán học nghiêm ngặt: 1. **Dễ tính toán theo chiều xuôi:** Cho trước $x \in X$, việc tính $y = f(x)$ là một bài toán thời gian đa thức $O(\text{poly}(|x|))$. 2. **Bất khả thi theo chiều ngược (Hard to Invert):** Cho trước $y \in Y$, việc tìm $x$ sao cho $f(x) = y$ là bài toán bất khả thi về mặt độ phức tạp tính toán đối với bất kỳ thuật toán cổ điển nào (thời gian tính toán vượt xa tuổi thọ vũ trụ). 3. **Cửa sập bí mật (Trapdoor Key):** Tồn tại một thông tin bổ trợ đặc biệt $K_{\text{priv}}$ (khóa bí mật). Khi biết $K_{\text{priv}}$, việc tính ngược $x = f^{-1}(y, K_{\text{priv}})$ trở thành một bài toán đa thức tường minh và hiệu quả.




Hiện nay, toán học thế giới công nhận ba bài toán khó kinh điển được dùng làm nền tảng cho các hàm cửa sập trong PKI cổ điển: 1. **Bài toán Phân tích Thừa số Nguyên tố (Integer Factorization Problem - IFP)** $\implies$ Hệ mật RSA. 2. **Bài toán Logarit Rời rạc (Discrete Logarithm Problem - DLP)** $\implies$ Giao thức Diffie-Hellman, ElGamal, DSA. 3. **Bài toán Logarit Rời rạc trên Đường cong Elliptic (ECDLP)** $\implies$ ECDH, ECDSA, Ed25519.

---

## 1.3. Bài Toán Phân Tích Thừa Số Nguyên Tố & Hệ Mật Mã RSA

### 1.3.1. Thuật Toán Sinh Khóa, Mã Hóa và Ký Số RSA

Được phát minh bởi Ron Rivest, Adi Shamir và Leonard Adleman năm 1977 tại MIT: 1. **Sinh khóa:** - Chọn ngẫu nhiên hai số nguyên tố rất lớn $p$ và $q$ (mỗi số 1024-bit hoặc 2048-bit). - Tính module công khai $n = p \cdot q$. Kích thước $n$ thường là 2048-bit hoặc 4096-bit. - Tính hàm Euler: $\phi(n) = (p-1)(q-1)$. - Chọn số mũ công khai $e$ thỏa mãn $1 < e < \phi(n)$ và $\gcd(e, \phi(n)) = 1$. Giá trị chuẩn công nghiệp luôn chọn $e = 65537 = 2^{16} + 1$ (số nguyên tố Fermat $F_4$) nhằm tối ưu hóa phép lũy thừa nhị phân (chỉ có đúng hai bit 1). - Tính số mũ bí mật $d$ bằng thuật toán Euclid mở rộng: $d \equiv e^{-1} \pmod{\phi(n)}$, tức $e \cdot d \equiv 1 \pmod{\phi(n)}$. - **Khóa công khai:** $K_{\text{pub}} = (n, e)$. - **Khóa bí mật:** $K_{\text{priv}} = (d, p, q)$.

2. **Mã hóa & Giải mã:**
   - Mã hóa bản rõ $m < n$: $c = m^e \pmod{n}$.
   - Giải mã bản mã $c$: $m = c^d \pmod{n}$.
   - Tính đúng đắn xuất phát từ Định lý Euler: $c^d \equiv (m^e)^d \equiv m^{e \cdot d} \equiv m^{1+k \cdot \phi(n)} \equiv m \cdot (m^{\phi(n)})^k \equiv m \cdot 1^k \equiv m \pmod{n}$.
3. **Chữ ký số RSA:**
   - Người ký tính hàm băm thông điệp $h = H(M)$.
   - Chữ ký số: $\sigma = h^d \pmod{n}$.
   - Người kiểm tra tính: $h' = \sigma^e \pmod{n}$. Nếu $h' == H(M)$, chữ ký hợp lệ.

### 1.3.2. Cơ Chế Đệm An Toàn (Padding Schemes) & Các Nguy Cơ Tấn Công

RSA "thô" (Textbook RSA) hoàn toàn không an toàn do tính chất **đồng cấu nhân**:

$$(m_1)^e \cdot (m_2)^e \equiv (m_1 \cdot m_2)^e \pmod{n}$$

Kẻ tấn công có thể giả mạo chữ ký trên thông điệp mới từ tích của hai chữ ký đã biết. Do đó, chuẩn mã hóa PKI bắt buộc áp dụng cơ chế đệm ngẫu nhiên: * **PKCS#1 v1.5:** Thêm chuỗi padding ngẫu nhiên có định dạng cố định. Tuy nhiên, PKCS#1 v1.5 dễ bị tổn thương trước tấn công Bleichenbacher (Million Message Attack) trên các máy chủ SSL/TLS nếu trả về lỗi giải mã không đồng nhất. * **RSA-OAEP (Optimal Asymmetric Encryption Padding):** Dùng cho mã hóa, bảo đảm tính an toàn IND-CCA2 (kháng tấn công bản mã chọn lọc thích nghi). * **RSA-PSS (Probabilistic Signature Scheme):** Được chuẩn hóa trong RFC 8017 / FIPS 186-5. Sử dụng muối ngẫu nhiên (salt) trước khi băm, chứng minh an toàn tuyệt đối trong mô hình Random Oracle Model. Các hệ thống PKI hiện đại được khuyến nghị chuyển dịch toàn bộ từ RSA PKCS#1 v1.5 sang RSA-PSS.

---

## 1.4. Bài Toán Logarit Rời Rạc & Mật Mã Đường Cong Elliptic (ECC)

### 1.4.1. Bài Toán Logarit Rời Rạc (DLP)

Cho nhóm cyclic $G$ cấp $q$ sinh bởi phần tử $g$. - **Bài toán chiều xuôi:** Cho $x \in \mathbb{Z}_q$, tính $y = g^x \in G$ (dễ dàng bằng thuật toán nhân đôi lũy thừa). - **Bài toán Logarit Rời rạc (DLP):** Cho $y \in G$, tìm $x \in \mathbb{Z}_q$ sao cho $g^x = y$. - Trên nhóm nhân $\mathbb{Z}_p^*$, các thuật toán Sàng trường số tổng quát (General Number Field Sieve - GNFS) và Index Calculus giải quyết DLP trong thời gian cận hàm mũ:

$$L_p\left[\frac{1}{3}, c\right] = \exp\left((c + o(1))(\ln p)^{1/3}(\ln \ln p)^{2/3}\right)$$

Do đó, để đạt mức an toàn 128-bit, module số nguyên tố $p$ phải có độ dài ít nhất **3072 bits**.

### 1.4.2. Mật Mã Đường Cong Elliptic (Elliptic Curve Cryptography - ECC)

Nhận định thiên tài của Neal Koblitz và Victor Miller năm 1985: Nếu thay thế nhóm nhân $\mathbb{Z}_p^*$ bằng nhóm các điểm trên đường cong Elliptic, các thuật toán Index Calculus hoàn toàn bị vô hiệu hóa!

1. **Phương trình Đường cong Elliptic:** Trên trường hữu hạn $\mathbb{F}_p$ ($p > 3$), đường cong Weierstrass không suy biến có phương trình:

   $$E : y^2 \equiv x^3 + a \cdot x + b \pmod{p}$$

   với điều kiện biệt thức $\Delta = 4a^3 + 27b^2 \not\equiv 0 \pmod{p}$.

2. **Luật Cộng Điểm Hình Học & Đại Số:** Tập hợp các điểm $P = (x, y) \in E(\mathbb{F}_p)$ cùng với **Điểm ở vô cực** $\mathcal{O}$ (phần tử trung hòa) tạo thành một nhóm Abel:
   - Với hai điểm $P = (x_1, y_1)$ và $Q = (x_2, y_2)$: Nếu $P \neq Q$, hệ số góc đường cát tuyến: $\lambda = \frac{y_2 - y_1}{x_2 - x_1} \pmod{p}$. Nếu $P = Q$ (nhân đôi điểm), hệ số góc tiếp tuyến: $\lambda = \frac{3x_1^2 + a}{2y_1} \pmod{p}$.
   - Tọa độ điểm tổng $R = P + Q = (x_3, y_3)$:

     $$x_3 = \lambda^2 - x_1 - x_2 \pmod{p}$$
     $$y_3 = \lambda(x_1 - x_3) - y_1 \pmod{p}$$

3. **Ưu thế Vượt Trội Của ECC Trong Hạ Tầng PKI:** Thuật toán mạnh nhất hiện nay giải bài toán ECDLP trên các đường cong chuẩn (NIST P-256, Curve25519) chỉ là Pollard's Rho với độ phức tạp hàm mũ đầy đủ:

$$\mathcal{O}(\sqrt{\pi \cdot n/2}) \approx 2^{128} \text{ phép tính đối với khóa 256-bit}$$

| Mức Độ An Toàn (Security Bits) | Kích Thước Khóa Đối Xứng (AES) | Kích Thước Khóa RSA (Bits) | Kích Thước Khóa ECC (Bits) | Tỉ Lệ Tiết Kiệm Kích Thước |
|---|---|---|---|---|
| 80-bit (Lỗi thời) | 2TDEA | 1024 | 160 | 6.4 : 1 |
| 112-bit (Tối thiểu) | 3TDEA | 2048 | 224 | 9.1 : 1 |
| **128-bit (Chuẩn hiện đại)** | **AES-128** | **3072** | **256** | **12.0 : 1** |
| **192-bit (An ninh cao)** | **AES-192** | **7680** | **384** | **20.0 : 1** |
| **256-bit (Tuyệt mật quốc gia)** | **AES-256** | **15360** | **521** | **29.5 : 1** |

Chính sự chênh lệch vượt trội này khiến toàn bộ hạ tầng Web PKI, thiết bị di động thông minh và các thẻ căn cước gắn chip hiện đại đều ưu tiên chuyển dịch sang **ECDSA** và **Ed25519** (Edwards curve RFC 8032) nhằm tiết kiệm băng thông mạng và năng lượng tính toán.

---

# CHƯƠNG 2: CẤU TRÚC DỮ LIỆU CHỨNG CHỈ X.509 V3 & QUY CÁCH MÃ HÓA ASN.1 DER

## 2.1. Cú Pháp ASN.1 & Quy Tắc Mã Hóa Nhị Phân DER

Chứng chỉ số không phải là một chuỗi văn bản ngẫu nhiên mà là một cấu trúc dữ liệu phân cấp được định nghĩa bằng chuẩn quốc tế **ASN.1 (Abstract Syntax Notation One - ITU-T X.680)** và được đóng gói nhị phân theo quy tắc **DER (Distinguished Encoding Rules - ITU-T X.690)**.

### 2.1.1. Cấu Trúc Khung Nhị Phân TLV (Tag - Length - Value)

Trong mã hóa DER, mỗi trường dữ liệu bắt buộc tuân theo định dạng 3 phần: 1. **Tag (Loại dữ liệu):** 1 byte (hoặc nhiều bytes) xác định kiểu: - `0x02`: `INTEGER` (Số nguyên) - `0x03`: `BIT STRING` (Chuỗi bit) - `0x04`: `OCTET STRING` (Chuỗi byte) - `0x05`: `NULL` - `0x06`: `OBJECT IDENTIFIER (OID)` - `0x0C`: `UTF8String` - `0x13`: `PrintableString` - `0x17`: `UTCTime` (YYMMDDHHMMSSZ) - `0x18`: `GeneralizedTime` (YYYYMMDDHHMMSSZ) - `0x30`: `SEQUENCE` (Cấu trúc danh sách tuần tự - bit Constructed được bật: `0x20 | 0x10 = 0x30`) - `0x31`: `SET` (Tập hợp không thứ tự)

2. **Length (Độ dài phần dữ liệu Value):**
   - **Dạng ngắn (Short form):** Nếu chiều dài $\leq 127$ bytes, trường Length chiếm đúng 1 byte với bit cao nhất bằng 0 (`0b0xxxxxxx`). Ví dụ: dài 45 bytes $\implies$ `0x2D`.
   - **Dạng dài (Long form):** Nếu chiều dài $> 127$ bytes, byte đầu tiên có bit cao nhất bằng 1 (`0b1xxxxxxx`), trong đó 7 bits sau chỉ số lượng byte tiếp theo dùng để biểu diễn chiều dài. Ví dụ: chiều dài 500 bytes (`0x01F4`), biểu diễn: `0x82 0x01 0xF4`.

- **Quy tắc bất biến của DER:** Khác với BER (Basic Encoding Rules) cho phép độ dài không xác định (indefinite length), DER bắt buộc phải dùng độ dài xác định ngắn nhất có thể. Điều này bảo đảm tính đơn nhất (canonical representation): **Một đối tượng ASN.1 chỉ có duy nhất một biểu diễn nhị phân DER tương ứng**, ngăn chặn hoàn toàn tấn công giả mạo chữ ký bằng cách biến đổi padding nhị phân (malleability attack).

---

## 2.2. Khung Dữ Liệu TBSCertificate Theo Chuẩn RFC 5280

Cấu trúc chứng chỉ X.509 v3 được mô tả bằng cú pháp ASN.1 chính thức trong RFC 5280:

```
Certificate ::= SEQUENCE {
    tbsCertificate          TBSCertificate,
    signatureAlgorithm      AlgorithmIdentifier,
    signatureValue          BIT STRING
}

TBSCertificate ::= SEQUENCE {
    version             [0] EXPLICIT Version DEFAULT v1,
    serialNumber            CertificateSerialNumber,
    signature               AlgorithmIdentifier,
    issuer                  Name,
    validity                Validity,
    subject                 Name,
    subjectPublicKeyInfo    SubjectPublicKeyInfo,
    issuerUniqueID      [1] IMPLICIT UniqueIdentifier OPTIONAL,
    subjectUniqueID     [2] IMPLICIT UniqueIdentifier OPTIONAL,
    extensions          [3] EXPLICIT Extensions OPTIONAL
}
```

```
+-------------------------------------------------------------------+
|                    X.509 v3 CERTIFICATE                           |
|                                                                   |
| +---------------------------------------------------------------+ |
| |                    TBSCertificate (To-Be-Signed)              | |
| |                                                               | |
| | 1. Version: v3 (0x02)                                         | |
| | 2. Serial Number: Số nguyên ngẫu nhiên dương (tối đa 20 bytes)| |
| | 3. Signature Algorithm: e.g. ecdsa-with-SHA256 / sha256WithRSA| |
| | 4. Issuer DN: CN=KMA Intermediate CA, O=KMA, C=VN             | |
| | 5. Validity: notBefore (02/10/2026) -> notAfter (02/10/2027)  | |
| | 6. Subject DN: CN=api.kma.edu.vn, O=KMA, C=VN                 | |
| | 7. SubjectPublicKeyInfo: Algorithm Identifier + Public Key Bit| |
| | 8. Extensions (X.509 v3 Extensions):                          | |
| |    - Basic Constraints: CA:FALSE                              | |
| |    - Key Usage: Digital Signature                             | |
| |    - Extended Key Usage: Server Auth, Client Auth             | |
| |    - SAN: DNS:api.kma.edu.vn, IP:10.0.0.1                     | |
| |    - CRL Distribution Points: http://crl.kma.edu.vn/ca.crl    | |
| |    - AIA: OCSP http://ocsp.kma.edu.vn                         | |
```

```
| +-------------------------------------------------------------+ |
|                                                                 |
| Signature Algorithm Identifier: ecdsa-with-SHA256 (OID 1.2.840...) |
| Signature Value: Chữ ký số của CA trên toàn bộ khối DER băm của   |
|                  TBSCertificate [BIT STRING]                    |
+-----------------------------------------------------------------+
```

---

## 2.3. Phân Tích Chuyên Sâu Các Phần Mở Rộng Trọng Yếu (Critical Extensions)

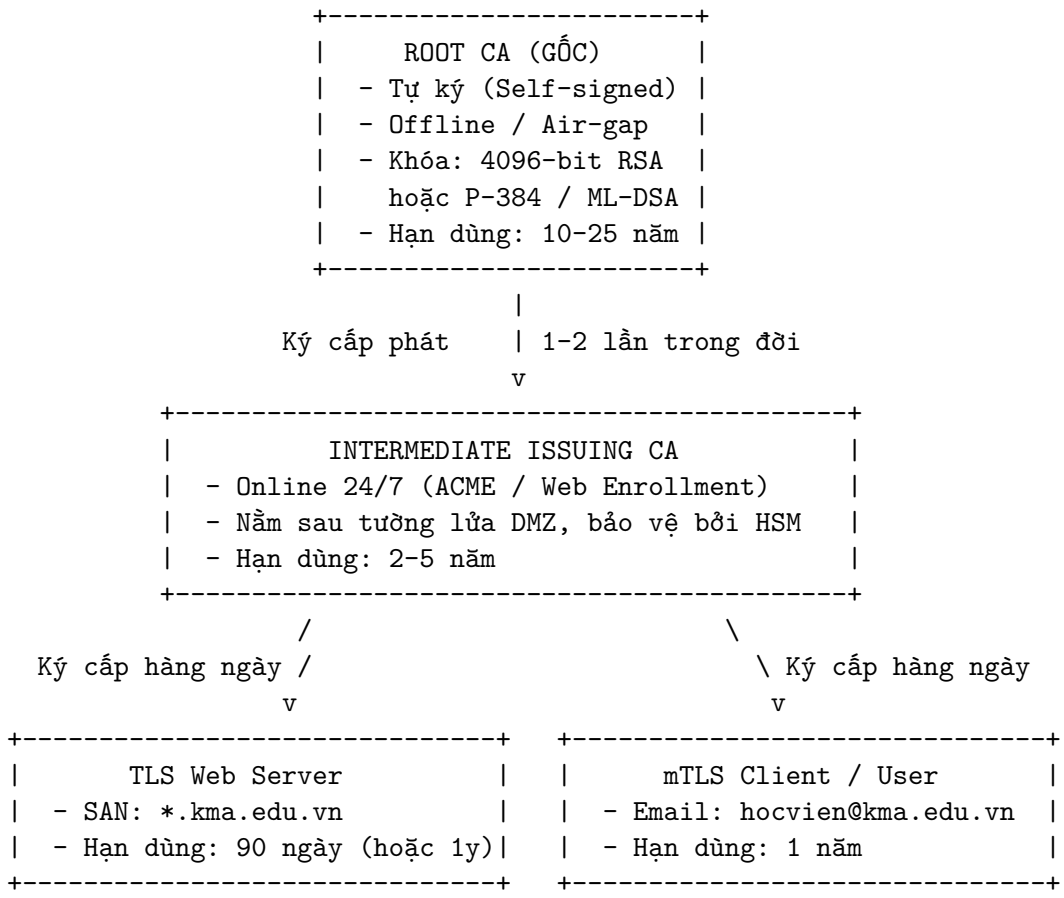
Phần mở rộng (Extensions) là nơi hiện thực hóa toàn bộ chính sách an ninh của PKI. Mỗi phần mở rộng gồm: `extnID` (OID), cờ `critical` (BOOLEAN, mặc định FALSE) và `extnValue` (OCTET STRING chứa dữ liệu DER đóng gói). > **Quy Tắc Vàng Của RFC 5280 Về Cờ Critical:** Nếu một phần mở rộng có cờ `critical = TRUE`, mọi ứng dụng hoặc thiết bị xác thực (trình duyệt, hệ điều hành) **BẮT BUỘC** phải hiểu và thực thi đúng ngữ nghĩa của phần mở rộng đó. Nếu không nhận biết hoặc không thể xử lý, hệ thống **BẮT BUỘC PHẢI TỪ CHỐI** chứng chỉ ngay lập tức!

1. **Basic Constraints (OID `2.5.29.19` - BẮT BUỘC CRITICAL trên CA):**
   - Chứa trường `cA` (BOOLEAN) và `pathLenConstraint` (INTEGER tùy chọn).
   - Nếu `cA = TRUE`: Chứng chỉ đại diện cho một nhà cầm quyền xác thực (CA), được phép ký cấp phát chứng chỉ khác.
   - Nếu `cA = FALSE`: Chứng chỉ thực thể cuối (End-Entity / Leaf Certificate), tuyệt đối không được dùng để ký chứng chỉ khác.
   - `pathLenConstraint = n`: Quy định chuỗi CA con bên dưới nó chỉ được phép có tối đa $n$ cấp Intermediate CA trung gian trước khi tới chứng chỉ lá. Nếu $n = 0$, CA này chỉ được phép ký trực tiếp cho End-Entity, không được ký cấp phát thêm bất kỳ Sub-CA nào nữa.
   - *Lỗ hổng thực tế:* Nếu quản trị viên sơ suất cấp chứng chỉ cho máy chủ nội bộ mà đặt `cA = TRUE`, kẻ tấn công chiếm được máy chủ đó có thể tự biến mình thành CA trung gian và phát hành chứng chỉ giả mạo cho mọi tên miền trên Internet!
2. **Key Usage (OID `2.5.29.15` - CRITICAL):** Định nghĩa các thao tác mật mã mà khóa công khai trong chứng chỉ được phép thực hiện:
   - `digitalSignature`: Ký thông điệp hoặc dữ liệu (trừ chứng chỉ và CRL).
   - `nonRepudiation`: Chống chối bỏ (thường dùng trong chữ ký văn bản số, pháp lý).
   - `keyEncipherment`: Mã hóa khóa đối xứng (dùng trong RSA Key Transport).
   - `keyAgreement`: Trao đổi khóa (dùng trong ECDH).
   - `keyCertSign`: Ký cấp phát chứng chỉ số (Chỉ được phép bật nếu `cA = TRUE`).
   - `cRLSign`: Ký danh sách thu hồi chứng chỉ (CRL).
3. **Extended Key Usage - EKU (OID `2.5.29.37`):** Xác định mục đích ứng dụng cụ thể:
   - `serverAuth` (`1.3.6.1.5.5.7.3.1`): Xác thực máy chủ Web TLS.
   - `clientAuth` (`1.3.6.1.5.5.7.3.2`): Xác thực người dùng / máy trạm mTLS.
   - `codeSigning` (`1.3.6.1.5.5.7.3.3`): Ký mã nguồn phần mềm, driver.
   - `timeStamping` (`1.3.6.1.5.5.7.3.8`): Cấp dấu thời gian RFC 3161.
4. **Subject Alternative Name - SAN (OID `2.5.29.17`):**
   - Danh sách định danh thực thể thay thế: `dNSName`, `iPAddress`, `uniformResourceIdentifier`, `rfc822Name` (email).
   - **Quy định nghiêm ngặt từ CA/B Forum Baseline Requirements v1.8+:** Các trình duyệt hiện đại (Chrome, Firefox, Safari) đã loại bỏ hoàn toàn việc đọc tên miền từ trường `Common Name (CN)` của Subject DN. Toàn bộ tên miền và địa chỉ IP hợp lệ **BẮT BUỘC PHẢI KHAI BÁO TRONG PHẦN MỞ RỘNG SAN**. Chứng chỉ chỉ có CN mà thiếu SAN sẽ bị trình duyệt báo lỗi `NET::ERR_CERT_COMMON_NAME_INVALID`.

# CHƯƠNG 3: KIẾN TRÚC PHÂN TẦNG CA, VÒNG ĐỜI KHÓA & QUY CHẾ CP/CPS (RFC 3647)

## 3.1. Các Mô Hình Phân Tầng Hạ Tầng Chứng Thực (CA Hierarchies)

Trong thực tế, một hệ thống PKI không bao giờ triển khai dưới dạng một CA đơn lẻ bởi vì nguyên tắc bảo vệ tài sản thông tin tối thượng: **Càng ít sử dụng khóa bí mật có giá trị cao thì hệ thống càng an toàn.**




**So Sánh Các Mô Hình Kiến Trúc:**

1. **Kiến trúc Single-Tier (Đơn cấp - Rủi ro đặc biệt nghiêm trọng):** Root CA ký trực tiếp cho tất cả máy chủ. Nếu máy chủ Root CA bị xâm nhập hoặc lộ khóa, toàn bộ hạ tầng sụp đổ và không thể thu hồi mà phải cài đặt lại Trust Store trên toàn bộ thiết bị người dùng.
2. **Kiến trúc Two-Tier (Hai cấp - Doanh nghiệp vừa):** 1 Root CA offline và 1 Issuing Intermediate CA online. Khi Issuing CA gặp sự cố, Root CA phát hành một bản thu hồi CRL và ký cấp một Issuing CA mới mà không làm gián đoạn Trust Anchor của người dùng.
3. **Kiến trúc Three-Tier (Ba cấp - Chuẩn Quốc gia & Tài chính):** Root CA $\rightarrow$ Policy CA (Phân tách theo địa lý hoặc phân cấp bảo mật) $\rightarrow$ Issuing CA $\rightarrow$ End-Entity. Tách biệt hoàn toàn quyền hạn vận hành và kiểm toán.

## 3.2. Nghi Thức Lễ Sinh Khóa (Key Ceremony) & Thiết Bị Phần Cứng HSM

Khóa bí mật của Root CA là linh hồn của hệ thống PKI. Việc tạo ra cặp khóa này không thể thực hiện tùy tiện trên máy tính cá nhân mà phải thông qua một nghi thức pháp lý và kỹ thuật trang trọng gọi là **Key Ceremony**.

### 3.2.1. Quy Trình 6 Bước Của Một Buổi Lễ Key Ceremony Chuẩn Quốc Tế

1. **Chuẩn bị Phòng Kín Cách Ly (Faraday Clean Room):** Phòng tổ chức phải được quét sóng điện từ, không có thiết bị thu phát vô tuyến, cách ly mạng hoàn toàn (Air-gapped), có hệ thống camera giám sát góc rộng ghi hình liên tục không góc chết.
2. **Kiểm Tra Niêm Phong Phần Cứng:** Các thiết bị HSM mới nguyên đai nguyên kiện được kiểm toán viên độc lập (Independent Auditor) kiểm tra số niêm phong (tamper-evident seal) và chứng thực chưa từng bị can thiệp.
3. **Khởi Động Môi Trường Live OS Sạch:** Máy chủ điều khiển nạp hệ điều hành chuyên dụng từ đĩa quang DVD-R (Write-Once) hoặc thẻ USB chỉ đọc có chữ ký số xác thực tính toàn vẹn của mã nhị phân.
4. **Phân Quyền Kiểm Soát Kép (Dual Control / M-of-N):** Khởi tạo thẻ quản trị viên HSM theo thuật toán phân chia bí mật Shamir: Phải có ít nhất $M$ trên tổng số $N$ người giữ khóa (Key Custodians) cùng cắm thẻ thông minh và nhập mã PIN thì mới mở được phân vùng bảo mật.
5. **Sinh Cặp Khóa Phần Cứng:** HSM tự kích hoạt bộ tạo số ngẫu nhiên vật lý (Hardware TRNG) để sinh cặp khóa Root bên trong bộ nhớ được bọc bảo vệ. Khóa bí mật **TUYỆT ĐỐI KHÔNG BAO GIỜ RA KHỎI HSM DƯỚI DẠNG BẢN RÕ (Plaintext)**.
6. **Ký Tự Chứng Thực & Niêm Phong Két Sắt:** Xuất chứng chỉ Root CA công khai, sao lưu bản mã hóa khóa sang thẻ bảo mật dự phòng, sau đó ngắt điện HSM, đóng gói niêm phong và lưu trữ trong hai két sắt chống cháy tại hai địa điểm địa lý khác nhau.

### 3.2.2. Thiết Bị Bảo Mật Phần Cứng HSM & Chuẩn Giao Tiếp PKCS#11

- **Tiêu chuẩn NIST FIPS 140-2 / FIPS 140-3:**
  - *Level 1:* Bảo vệ phần mềm cơ bản.
  - *Level 2:* Vỏ kim loại có khóa và tem niêm phong chống cạy mở.
  - *Level 3:* Kháng can thiệp tích cực — Tự động hủy khóa ngay lập tức (Zeroization) nếu phát hiện hành vi cạy nắp hoặc tháo vỏ bảo vệ.
  - *Level 4:* Bảo vệ mức vật lý tối thượng — Tự hủy khóa nếu phát hiện thay đổi nhiệt độ đột ngột (tấn công làm lạnh sâu) hoặc biến đổi điện áp nguồn.
- **Chuẩn giao diện PKCS#11 (Cryptoki):** Định nghĩa API chuẩn C độc lập với nhà sản xuất (Thales, Entrust, Yubico) cho phép các ứng dụng (OpenSSL, Step-CA, HashiCorp Vault) ra lệnh cho HSM ký số mà không bao giờ cần đọc khóa bí mật vào RAM máy tính:

```
C_Initialize(...);
C_OpenSession(slotID, CKF_SERIAL_SESSION | CKF_RW_SESSION, ...);
C_Login(hSession, CKU_USER, pin, pinLen);
C_SignInit(hSession, &mechanism, hPrivateKey);
C_Sign(hSession, pData, ulDataLen, pSignature, &ulSignatureLen);
```

---

### 3.3. Khung Quy Chế Chứng Thực CP & CPS (RFC 3647)

Một hệ thống PKI chỉ có giá trị pháp lý khi đi kèm với hai văn kiện nền tảng: * **Chính Sách Chứng Thực (Certificate Policy - CP):** Tuyên ngôn cấp quản lý nêu rõ chứng chỉ được cấp cho ai, áp dụng cho mục đích gì và mức độ tin cậy đến đâu. * **Quy Chế Thực Hành Chứng Thực (Certification Practice Statement - CPS):** Tài liệu hướng dẫn kỹ thuật chi tiết tường tận cách thức CA vận hành để đạt được các mục tiêu đề ra trong CP.

RFC 3647 chuẩn hóa cấu trúc của CP và CPS thành **8 đề mục cốt lõi**: 1. **Giới thiệu chung (Introduction):** Nhận diện tài liệu, các bên tham gia (CA, RA, Thuê bao Subscriber, Người tin cậy Relying Party), phạm vi khả dụng. 2. **Trách nhiệm công bố và lưu trữ (Publication & Repository Controls):** Địa chỉ kho lưu trữ trực tuyến, tần suất cập nhật CRL/CPS. 3. **Định danh và xác thực (Identification & Authentication):** Thủ tục xác minh danh tính tổ chức/cá nhân khi đăng ký lần đầu và khi thu hồi. 4. **Vòng đời hoạt động của chứng chỉ (Certificate Life-Cycle Operations):** Quy trình nộp đơn, cấp phát, gia hạn và thu hồi chứng chỉ. 5. **Kiểm soát cơ sở vật chất, quản lý và vận hành (Facility, Management Controls):** An ninh phòng máy chủ, kiểm soát truy cập vật lý, phòng cháy chữa cháy, sao lưu thảm họa. 6. **Kiểm soát kỹ thuật an ninh (Technical Security Controls):** Chuẩn thế hệ khóa, độ dài khóa, chuẩn HSM, cơ chế kiểm soát kép, an ninh mạng phân vùng DMZ. 7. **Hồ sơ định dạng (Certificate, CRL, and OCSP Profiles):** Cấu trúc chính xác các OID, thuật toán ký, các trường mở rộng Critical/Non-critical. 8. **Đánh giá và kiểm toán tuân thủ (Compliance Audit & Assessments):** Cơ quan kiểm toán độc lập, chu kỳ kiểm toán hàng năm (WebTrust, ETSI EN 319 411).

---

## CHƯƠNG 4: THUẬT TOÁN XÁC THỰC ĐƯỜNG DẪN TIN CẬY & CƠ CHẾ THU HỒI CHỨNG CHỈ

### 4.1. Thuật Toán Xác Thực Chuỗi Chứng Chỉ (RFC 5280 §6)

Khi người dùng truy cập một website bảo mật, trình duyệt phải dựng một chuỗi chứng chỉ từ chứng chỉ lá $C_0$ ngược về một chứng chỉ gốc $C_n$ nằm trong cơ sở dữ liệu tin cậy cục bộ (Local Trust Store):

$$C_0(\text{Leaf}) \rightarrow C_1(\text{Issuing CA}) \rightarrow C_2(\text{Intermediate CA}) \rightarrow C_n(\text{Trust Anchor / Root CA})$$

Thuật toán xác thực đường dẫn (Path Validation Algorithm) duyệt qua từng mắt xích từ $i = 1$ đến $n$ và thực hiện tuần tự **6 bước kiểm định toán học nghiêm ngặt**: 1. **Kiểm tra chữ ký số:** Sử dụng khóa công khai của chứng chỉ cha $C_i$ để giải mã và kiểm tra chữ ký trên khối TBSCertificate của chứng chỉ con $C_{i-1}$. 2. **Kiểm tra thời gian hiệu lực:** Thời điểm hiện tại $T_{\text{now}}$ phải nằm trong khoảng:

$$C_{i-1}.\text{notBefore} \leq T_{\text{now}} \leq C_{i-1}.\text{notAfter}$$

3. **Khớp nối chuỗi định danh (Name Chaining):** Tên định danh của người phát hành trong chứng chỉ con phải trùng khớp hoàn toàn từng byte nhị phân với tên chủ thể của chứng chỉ cha:

$$C_{i-1}.\text{Issuer} == C_i.\text{Subject}$$

4. **Kiểm tra quyền hạn CA (Basic Constraints):** Đối với tất cả các mắt xích trung gian ($i \geq 1$), chứng chỉ $C_i$ bắt buộc phải có phần mở rộng `Basic Constraints` với cờ `cA = TRUE`. 5. **Kiểm tra giới hạn độ sâu (Path Length Constraint):** Nếu $C_i$ có quy định `pathLenConstraint = k`, số lượng chứng chỉ CA trung gian nằm giữa nó và chứng chỉ thực thể cuối không được vượt quá $k$. 6. **Kiểm tra trạng thái thu hồi (Revocation Status):** Kiểm tra xem số seri của $C_{i-1}$ có bị liệt kê trong danh sách thu hồi CRL hoặc nhận phản hồi `REVOKED` từ OCSP Responder hay không.

### 4.2. Cơ Chế Thu Hồi: CRL vs. OCSP vs. OCSP Stapling

Một chứng chỉ có thể bị hủy bỏ giá trị trước khi hết hạn do nhiều nguyên nhân: lộ khóa bí mật (`keyCompromise`), thay đổi thông tin định danh (`affiliationChanged`), hoặc đơn vị ngừng hoạt động. Ba cơ chế kiểm tra thu hồi được phát triển qua các thời kỳ:

```
1. CRL (Danh sách thu hồi tĩnh):
   Client -------- Tải toàn bộ file CRL (dung lượng lớn hàng MB) --------> CA CRL Server
   (Nhược điểm: Tải nặng, độ trễ cập nhật lớn, gây chậm kết nối)

2. OCSP (Tra cứu trực tuyến):
   Client -------- Truy vấn: Chứng chỉ Serial #12345 còn sống không? -------> OCSP Responder
          <------- Phản hồi: Trạng thái GOOD (ký bởi CA) ------------------
   (Nhược điểm: Lộ lịch sử duyệt web của Client cho CA; nguy cơ Soft-Fail bị chặn)

3. OCSP STAPLING (Khuyến nghị chuẩn hiện đại TLS 1.3):
   Web Server tự truy vấn OCSP Responder định kỳ (mỗi giờ) và lưu đệm phản hồi.
   Client <======= Gói bắt tay TLS 1.3 kèm luôn phản hồi OCSP đã ký ======== Web Server
   (Ưu điểm tuyệt đối: Tốc độ tối đa 0-RTT, bảo mật riêng tư 100%, không nghẽn CA)
```

**So Sánh Kỹ Thuật Chi Tiết:**

| Tiêu Chí Kỹ Thuật | CRL (RFC 5280) | OCSP (RFC 6960) | OCSP Stapling (RFC 6066 / 7633) |
|---|---|---|---|
| **Phương thức truyền tải** | File tĩnh qua HTTP/FTP | Giao thức nhị phân HTTP POST/GET | Kẹp trong gói TLS Handshake |
| **Băng thông Client** | Rất nặng (tải danh sách lớn) | Rất nhẹ (vài trăm bytes) | Không tốn thêm kết nối ngoài |
| **Quyền riêng tư (Privacy)** | Tốt (CA không biết ai bị tra cứu) | Kém (CA biết IP người dùng truy cập web nào) | Hoàn hảo (CA không biết danh tính client) |
| **Độ trễ kết nối mạng** | Lớn (nếu file CRL chưa cache) | Thêm 1 RTT tới OCSP server | 0 RTT (có sẵn trong gói TLS) |
| **Hành vi khi mạng lỗi** | Soft-fail (bỏ qua kiểm tra) | Soft-fail (nguy cơ MitM chặn) | **Hard-fail** khi bật Must-Staple |

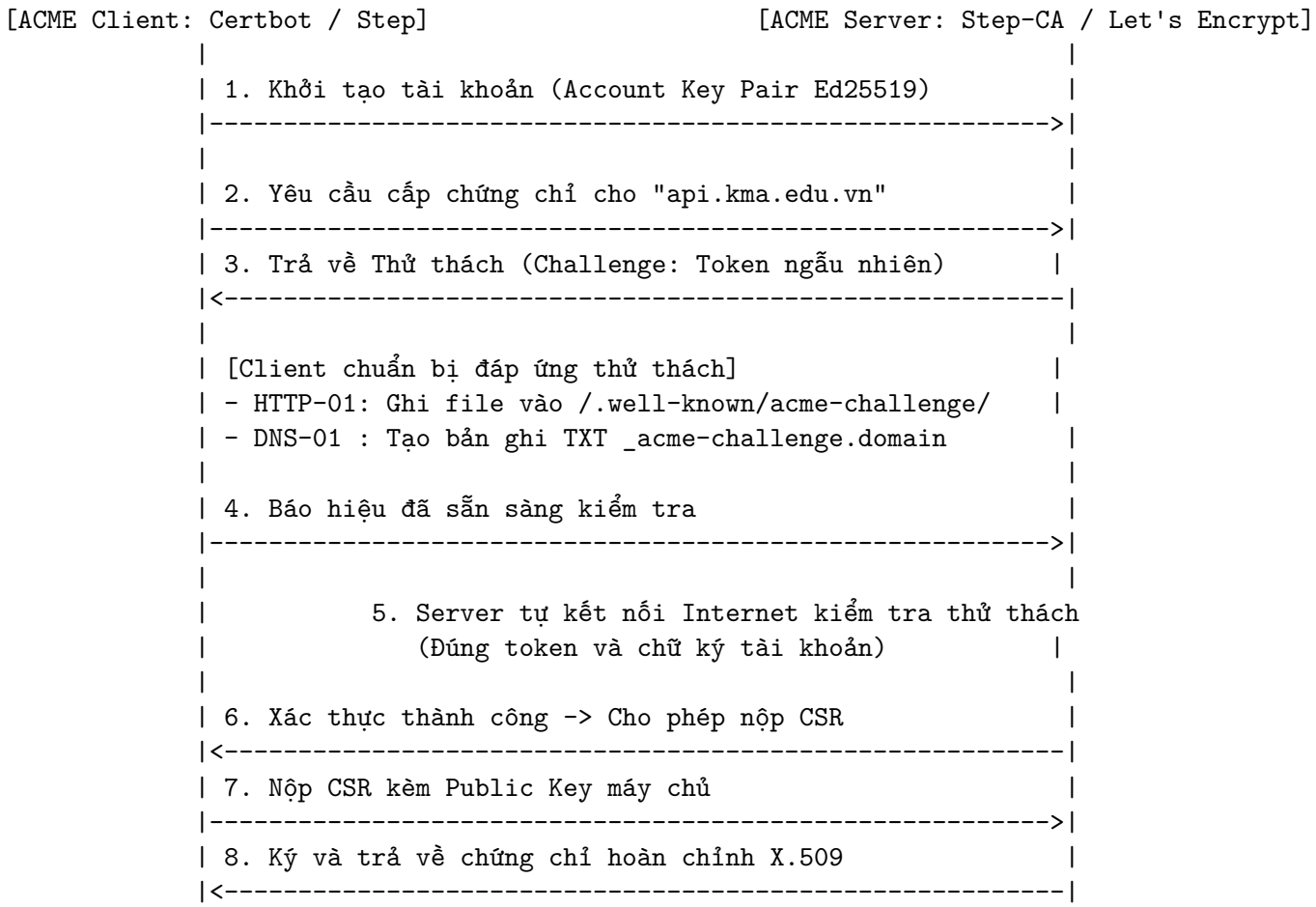
---

# CHƯƠNG 5: GIAO THỨC QUẢN TRỊ TỰ ĐỘNG ACME (RFC 8555) & HẠ TẦNG ZERO TRUST PKI

### 5.1. Cuộc Cách Mạng Tự Động Hóa Vòng Đời Chứng Chỉ Với ACME (RFC 8555)

Năm 2020, Apple, Google và Mozilla chính thức áp đặt giới hạn thời hạn sống của chứng chỉ TLS xuống còn **398 ngày**. Năm 2024, Google đề xuất lộ trình rút ngắn tiếp xuống **90 ngày**, và trong tương lai là **45 ngày**. Việc quản lý chứng chỉ thủ công bằng con người (tạo CSR, nộp đơn, chờ duyệt, tải về, cấu hình máy chủ) hoàn toàn phá sản.

Giao thức **ACME (Automated Certificate Management Environment - RFC 8555)** do Let's Encrypt tiên phong và IETF chuẩn hóa đã giải quyết bài toán này thông qua tự động hóa hoàn toàn 100%:




**Các Loại Thử Thách ACME Phổ Biến:**

1. **HTTP-01 Challenge:** Máy chủ ACME truy vấn qua cổng HTTP 80 để đọc token. Phù hợp cho máy chủ đơn lẻ, nhưng không cấp được chứng chỉ Wildcard (`*.domain.com`).
2. **DNS-01 Challenge:** Client sử dụng API của máy chủ DNS để tự động tạo bản ghi TXT. Đây là phương pháp mạnh mẽ nhất, hỗ trợ chứng chỉ Wildcard và hoạt động tốt ngay cả với máy chủ nằm sâu trong mạng nội bộ không mở cổng ra Internet.
3. **TLS-ALPN-01 Challenge:** Dành riêng cho các hệ thống reverse proxy (HAProxy, Traefik), đàm phán qua giao thức TLS ALPN chuyên dụng trên cổng 443 mà không cần can thiệp tầng HTTP.

---

## 5.2. PKI Trong Kiến Trúc Mạng Không Tin Cậy (Zero Trust PKI)

Mô hình phòng thủ chu vi truyền thống ("bên ngoài nguy hiểm, bên trong an toàn") đã hoàn toàn lỗi thời. Kiến trúc **Zero Trust** áp dụng nguyên tắc: **Luôn luôn xác thực, không bao giờ tin tưởng bất kỳ ai dù đang ở trong mạng nội bộ**.

- **mTLS (Mutual TLS) Toàn Diện:** Mọi kết nối giữa microservices A và microservices B đều bắt buộc cả hai bên phải xuất trình chứng chỉ X.509 để xác thực hai chiều và mã hóa đường truyền.

- **Chứng Chỉ Biểu Kiến (Ephemeral Certificates):** Khóa bí mật và chứng chỉ được sinh tự động bởi HashiCorp Vault hoặc Step-CA với thời gian sống cực ngắn (từ 1 giờ đến 24 giờ). Khi chứng chỉ hết hạn, hệ thống tự động xoay vòng (key rotation). Kẻ tấn công nếu có đánh cắp được khóa bí mật trong bộ nhớ thì giá trị sử dụng cũng đã hết hạn sau ít phút.

---

# CHƯƠNG 6: CÁC KỊCH BẢN TẤN CÔNG HẠ TẦNG PKI & CHIẾN LƯỢC PHÒNG THỦ TOÀN DIỆN

## 6.1. Bài Học Xương Máu Từ Các Thảm Họa PKI Lịch Sử

PKI được xây dựng dựa trên sự ủy thác. Nếu một CA gốc trong Trust Store bị xâm nhập, kẻ tấn công có quyền lực tối thượng để giả mạo bất kỳ dịch vụ nào trên thế giới.

1. **Vụ Án DigiNotar (Hà Lan - 2011):**
   - *Bối cảnh:* DigiNotar là CA công cộng uy tín của chính phủ Hà Lan, nằm trong Trust Store mặc định của Windows, iOS, Android, Firefox.
   - *Kịch bản tấn công:* Hacker thâm nhập vào mạng nội bộ của DigiNotar do hệ thống thiếu phân tách mạng và mật khẩu quản trị yếu. Root CA bị để ở trạng thái trực tuyến. Kẻ tấn công phát hành hơn 500 chứng chỉ giả mạo cho các tên miền trọng yếu: `*.google.com`, `*.torproject.org`, `*.microsoft.com`.
   - *Hậu quả:* Hơn 300.000 người dùng Internet tại Iran đã bị tấn công Man-in-the-Middle đọc trộm toàn bộ email và tài khoản cá nhân. Google và Microsoft đã tung bản vá khẩn cấp loại bỏ hoàn toàn DigiNotar khỏi Trust Store, dẫn tới việc công ty này nộp đơn phá sản sau đó 1 tháng.
2. **Vũ Khí Mạng Flame (2012):**
   - *Kịch bản:* Nhóm phát triển mã độc gián điệp Flame đã thực hiện một cuộc tấn công toán học kỳ công: Khai thác lỗ hổng va chạm tiền ảnh (chosen-prefix collision) trên hàm băm MD5 mà Microsoft vẫn sử dụng để ký chứng chỉ dịch vụ Terminal Server.
   - *Khai thác:* Kẻ tấn công tạo ra một chứng chỉ giả mạo có cùng mã băm MD5 với chứng chỉ hợp lệ của Microsoft, từ đó ký mã độc giả dạng bản cập nhật chính thức của Windows Update để lây nhiễm vào các cơ sở hạ tầng trọng yếu tại Trung Đông.

---

## 6.2. Kỹ Thuật Tấn Công Active Directory Certificate Services (AD CS)

Active Directory Certificate Services (AD CS) là thành phần PKI phổ biến nhất trong các tập đoàn lớn toàn cầu. Năm 2021, Will Schroeder và Lee Christensen (SpecterOps) đã công bố nghiên cứu gây chấn động chỉ ra hàng loạt cấu hình sai sót nghiêm trọng cho phép leo thang đặc quyền từ người dùng cấp thấp lên Quản trị viên miền (Domain Admin):

- **Kỹ thuật ESC1 (Misconfigured Certificate Template):**
  - Mẫu chứng chỉ (Template) thỏa mãn đồng thời 3 điều kiện chết người:
    1. Cấp quyền cho nhóm người dùng bình thường (`Domain Users`) được nộp đơn xin cấp chứng chỉ.
    2. Bật cờ `ENROLLEE_SUPPLIES_SUBJECT`: Cho phép người nộp đơn tùy ý điền tên Subject Alternative Name (SAN) trong CSR.
    3. Cấu hình Extended Key Usage (EKU) có chứa `Client Authentication` (`1.3.6.1.5.5.7.3.2`) hoặc `Smart Card Logon`.

- *Khai thác:* Kẻ tấn công sử dụng công cụ `Certipy` yêu cầu một chứng chỉ với SAN giả mạo là tài khoản `Administrator@domain.local`. Sau khi nhận được chứng chỉ từ AD CS, kẻ tấn công dùng chứng chỉ đó yêu cầu vé Kerberos TGT (Ticket Granting Ticket) để chiếm quyền điều khiển toàn bộ mạng công ty.

```
# Lệnh trinh sát và khai thác ESC1 bằng công cụ Certipy:
certipy find -u user@corp.local -p Password123 -dc-ip 10.0.0.1 -vulnerable
certipy req -u user@corp.local -p Password123 -ca Corp-CA -template ESC1-Template -upn administra
certipy auth -pfx administrator.pfx -dc-ip 10.0.0.1
```

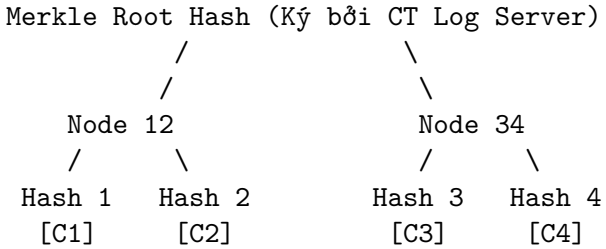
- **Biện Pháp Phòng Thủ:**
  - Bỏ cờ `ENROLLEE_SUPPLIES_SUBJECT` trên mọi template có tính năng Client Authentication.
  - Thiết lập cơ chế phê duyệt thủ công (`CA administrator approval`) cho các chứng chỉ nhạy cảm.
  - Giám sát Windows Event Log ID `4886` (Yêu cầu cấp chứng chỉ) và `4887` (Đã cấp chứng chỉ) bằng các luật phát hiện **Sigma rules**.

---

### 6.3. Hệ Thống Minh Bạch Chứng Chỉ (Certificate Transparency - RFC 6962)

Để giải quyết triệt để vấn đề CA cấp lén lút chứng chỉ giả mạo như vụ DigiNotar, Google đã khởi xướng chuẩn **Certificate Transparency (CT Logs - RFC 6962)**:

1. **Nguyên Lý Hoạt Động:** Mọi chứng chỉ muốn được trình duyệt (Chrome, Safari) tin cậy **BẮT BUỘC** phải được ghi vào các máy chủ CT Log công khai trước khi phát hành.
2. **Cấu Trúc Cây Merkle (Merkle Hash Tree):**
   - CT Log là một cuốn sổ cái chỉ thêm (Append-Only Cryptographic Ledger). Dữ liệu được tổ chức dưới dạng cây nhị phân Merkle Tree.
   - Mỗi nút lá là một chứng chỉ đã được nộp. Nút cha là mã băm của hai nút con: $N_{\text{parent}} = H(N_{\text{left}} \parallel N_{\text{right}})$.
   - Gốc cây (Merkle Tree Root) đại diện cho toàn bộ trạng thái lịch sử của hàng tỷ chứng chỉ đã phát hành.




3. **Signed Certificate Timestamp (SCT):** Khi CA gửi chứng chỉ tạm (Pre-certificate) lên CT Log, Log server trả về một biên nhận mật mã gọi là SCT. SCT là bằng chứng cam kết rằng chứng chỉ này sẽ được đưa vào cây Merkle trong vòng tối đa 24 giờ (Maximum Merge Delay - MMD). SCT được nhúng trực tiếp vào chứng chỉ X.509 chính thức dưới dạng một Extension.
4. **Kiểm Định Tuân Thủ Với ZLint:** Trước khi đưa chứng chỉ ra môi trường production, các tổ chức CA sử dụng công cụ nguồn mở **ZLint** để quét tự động hơn 250 điều khoản kỹ thuật của chuẩn CA/B Forum, bảo đảm 100% chứng chỉ không mắc các lỗi sai sót về định dạng bit hay OID.

---

# CHƯƠNG 7: CHUYỂN DỊCH HỆ THỐNG SANG MẬT MÃ HẬU LƯỢNG TỬ (PQC MIGRATION)

## 7.1. Mối Đe Dọa Từ Máy Tính Lượng Tử & Chiến Lược HNDL

Năm 1994, Peter Shor công bố thuật toán lượng tử chứng minh rằng: Một máy tính lượng tử lý tưởng (Cryptanalytically Relevant Quantum Computer - CRQC) có thể tìm chu kỳ hàm số và giải quyết đồng thời bài toán phân tích thừa số nguyên tố và logarit rời rạc trong **thời gian đa thức**:

$$\mathcal{O}\left((\log N)^3\right)$$

Điều này đồng nghĩa với việc toàn bộ thuật toán RSA, DSA, ECDSA và ECDH đang bảo vệ Internet **sẽ hoàn toàn sụp đổ chỉ sau một đêm** khi máy tính lượng tử đạt đủ số lượng Qubit vật lý ổn định.

Mối đe dọa không nằm ở tương lai 10 năm nữa mà đang diễn ra **ngay trong giây phút này** thông qua chiến lược tấn công:

**Harvest Now, Decrypt Later (HNDL) — Thu thập ngay, Giải mã sau**

Các cơ quan tình báo và nhóm tội phạm mạng tinh vi đang bí mật thu thập và lưu trữ hàng terabyte lưu lượng mã hóa HTTPS, dữ liệu ngoại giao, hồ sơ bệnh án và giao dịch ngân hàng của các quốc gia. Khi máy tính lượng tử ra đời, toàn bộ kho dữ liệu lịch sử này sẽ bị giải mã hồi tố, làm lộ toàn bộ bí mật nhà nước và bí mật kinh doanh!

---

## 7.2. Bộ Tiêu Chuẩn Mật Mã Hậu Lượng Tử Chính Thức Của NIST (08/2024)

Sau cuộc thi tuyển chọn toàn cầu kéo dài gần một thập kỷ, ngày 13/08/2024, Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) đã chính thức ban hành bộ tiêu chuẩn liên bang:

### 7.2.1. NIST FIPS 203: Chuẩn Đóng Gói Khóa ML-KEM (Module-Lattice KEM)

- Dựa trên thuật toán nguyên bản **CRYSTALS-Kyber**.
- Dựa trên bài toán khó **Module Learning With Errors (M-LWE)** trên vành đa thức hữu hạn: Cho ma trận đa thức **A**, vector bí mật **s** và vector sai số nhỏ **e**, việc tìm **s** từ $\mathbf{b} = \mathbf{As} + \mathbf{e}$ là bài toán NP-hard ngay cả với máy tính lượng tử.
- **Ba cấp độ an ninh:**
  - `ML-KEM-512`: Tương đương mức an ninh AES-128 (NIST Level 1).
  - `ML-KEM-768`: Tương đương mức an ninh AES-192 (NIST Level 3 - Khuyến nghị chuẩn chung).
  - `ML-KEM-1024`: Tương đương mức an ninh AES-256 (NIST Level 5 - Dành cho hạ tầng tối mật).

### 7.2.2. NIST FIPS 204: Chuẩn Chữ Ký Số ML-DSA (Module-Lattice DSA)

- Dựa trên thuật toán nguyên bản **CRYSTALS-Dilithium**.
- Áp dụng kiến trúc Fiat-Shamir with Aborts trên vành mạng lưới Module-LWE và Module-SIS.
- **Ba cấp độ an ninh:** `ML-DSA-44`, `ML-DSA-65` (Khuyến nghị chuẩn), `ML-DSA-87`.

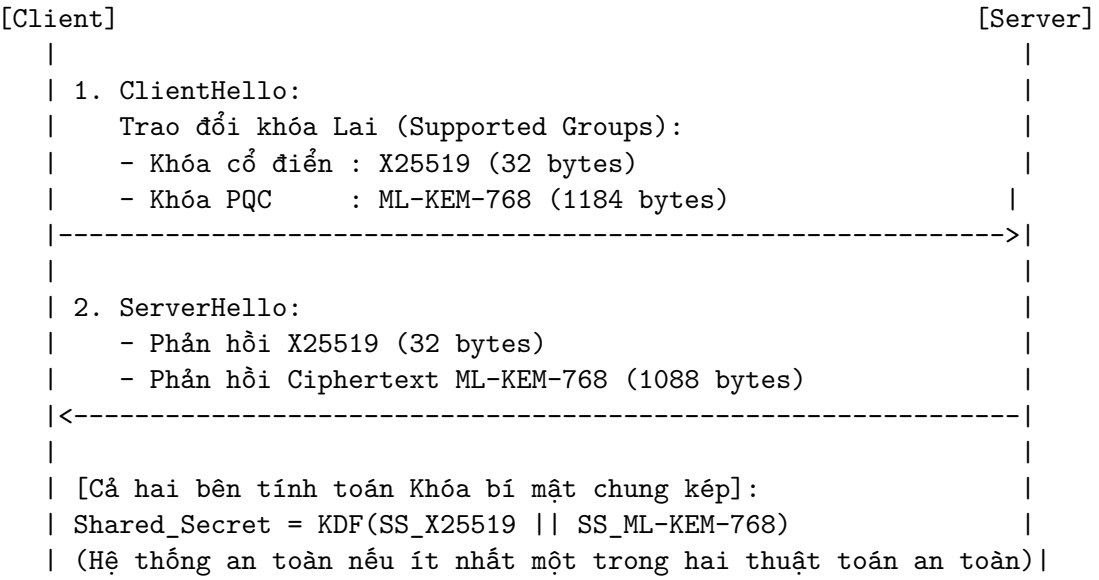
#### 7.2.3. NIST FIPS 205: Chuẩn Chữ Ký Số Phi Trạng Thái SLH-DSA (SPHINCS+)

- Dựa trên toán học hàm băm phi cấu trúc (Stateless Hash-Based).
- Ưu điểm: Cơ sở an toàn hoàn toàn độc lập với toán học mạng lưới (được xem là tuyến phòng thủ dự phòng an toàn tuyệt đối nếu một ngày toán học mạng lưới bị giải mã). Nhược điểm: Chữ ký có kích thước rất lớn (hơn 17 KB - 40 KB).

---

### 7.3. Kiến Trúc Bắt Tay Lai (Hybrid TLS 1.3 & Hybrid Certificates)

Việc chuyển dịch từ mật mã cổ điển sang PQC không thể diễn ra đột ngột mà phải thông qua cơ chế **Bắt tay lai (Hybrid Approach)** theo chuẩn IETF:




**Thử Thách Kỹ Thuật Khi Chuyển Dịch Lên Môi Trường Sản Xuất:**

1. **Bùng Nổ Kích Thước Khóa & Chữ Ký:**
   - Khóa ECDSA P-256: Public Key 64 bytes, Signature 64 bytes.
   - Khóa ML-DSA-65: Public Key **1952 bytes**, Signature **3309 bytes**.
2. **Hiện Tượng Phân Mảnh Gói Tin TCP (TCP MTU Packet Fragmentation):**
   - MTU tiêu chuẩn mạng Ethernet là 1500 bytes. Một chứng chỉ hoặc chữ ký ML-DSA vượt quá kích thước 1 MTU bắt buộc phải bị phân mảnh thành 3 - 4 khung tin IP.
   - Trên mạng di động (4G/5G) hoặc kết nối mạng vệ tinh có tỉ lệ mất gói cao, việc phân mảnh gói tin làm tăng đột biến độ trễ bắt tay mạng (Handshake Latency) và tăng nguy cơ rớt kết nối. Đây là bài toán kỹ thuật trọng tâm mà học viên Nhóm 3 sẽ đo kiểm thực tế trong đồ án môn học.

---

# CHƯƠNG 8: KHUNG PHÁP LÝ, QUY CHUẨN KỸ THUẬT & HẠ TẦNG CHỮ KÝ SỐ QUỐC GIA

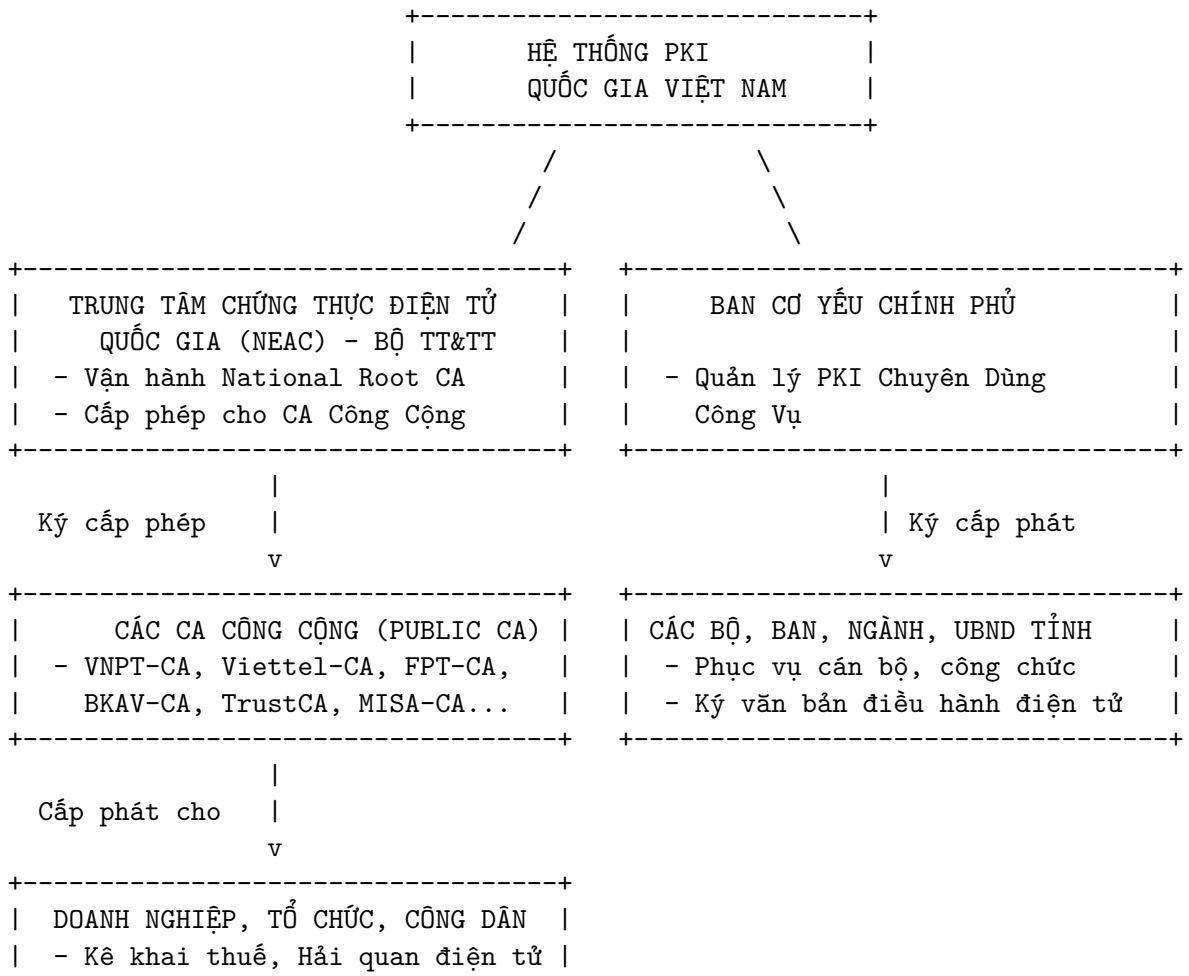
## 8.1. Hệ Thống Luật Pháp & Quy Chuẩn Kỹ Thuật Việt Nam

Tại Việt Nam, chữ ký số và hạ tầng khóa công khai được điều chỉnh bởi một hành lang pháp lý hoàn chỉnh và chặt chẽ: 1. **Luật Giao dịch điện tử số 20/2023/QH15 (Chính thức có hiệu lực từ ngày 01/07/2024):** - Thay thế toàn diện Luật Giao dịch điện tử năm 2005. - Quy định phân loại chi tiết: **Chữ ký điện tử chuyên dùng**, **Chữ ký số chuyên dùng công vụ** và **Chữ ký số công cộng**. - Khẳng định giá trị pháp lý tương đương chữ ký tay của cá nhân và con dấu của tổ chức. - Bổ sung quy định về **Dịch vụ Tin cậy (Trust Services)** bao gồm: Dịch vụ cấp dấu thời gian (Time-stamping), Dịch vụ chứng thực thông điệp dữ liệu, và Dịch vụ chứng thực chữ ký số. 2. **Nghị định 130/2018/NĐ-CP:** Hướng dẫn chi tiết thi hành Luật Giao dịch điện tử về chữ ký số và dịch vụ chứng thực chữ ký số. 3. **Thông tư số 16/2019/TT-BTTTT & Thông tư số 31/2020/TT-BTTTT:** Quy định danh mục tiêu chuẩn kỹ thuật bắt buộc áp dụng cho chữ ký số và thiết bị lưu khóa: - Thuật toán băm: Tối thiểu SHA-256 (loại bỏ hoàn toàn SHA-1). - Thuật toán khóa công khai: RSA tối thiểu 2048-bit hoặc ECC tối thiểu 256-bit. - Giao thức kiểm tra trạng thái: Bắt buộc hỗ trợ song song cả CRL và OCSP trực tuyến.

---

## 8.2. Kiến Trúc Hạ Tầng Chữ Ký Số Quốc Gia

Hạ tầng PKI Việt Nam được tổ chức theo mô hình hai nhánh quốc gia độc lập:



```
|  - Hóa đơn điện tử, Ngân hàng số  |
+-----------------------------------+
```

---

### 8.3. Tiêu Chuẩn Thiết Bị Lưu Khóa Bí Mật & Ký Số Từ Xa (Remote Signing)

1. **Thiết Bị Cứng Cục Bộ (USB Token / Smartcard):**
   - Thiết bị phải đạt chứng chỉ an toàn quốc tế **Common Criteria (CC) mức EAL4+** hoặc **NIST FIPS 140-2 Level 2/3**.
   - Khóa bí mật được sinh trực tiếp bên trong chip bảo mật và không bao giờ cho phép sao chép ra ngoài.
   - Có cơ chế khóa tự động sau một số lần nhập sai mã PIN (thường là 5 lần).
2. **Ký Số Từ Xa (Remote Signing / Cloud HSM):**
   - Người dùng không cần mang theo thiết bị phần cứng USB Token cồng kềnh. Khóa bí mật được lưu tập trung trong các cụm thiết bị HSM đạt chuẩn FIPS 140-2 Level 3 tại trung tâm dữ liệu của nhà cung cấp dịch vụ tin cậy (TSP).
   - Xác thực kích hoạt chữ ký thông qua phương thức xác thực đa yếu tố (MFA): Sinh trắc học (FIDO2 / FaceID / Vân tay) kết hợp mã OTP thông báo qua ứng dụng an toàn.
   - Quy trình ký số từ xa bắt buộc tuân thủ tiêu chuẩn Châu Âu **eIDAS (EN 419 241-1 / EN 419 241-2)** bảo đảm người dùng duy trì quyền kiểm soát duy nhất (Sole Control) đối với khóa bí mật của mình.

---

## PHỤ LỤC A: CẨM NANG 50 LỆNH OPENSSL 3.5 THỰC CHIẾN

```
# ==========================================================================
# PHẦN 1: QUẢN LÝ KHÓA CỔ ĐIỂN & ĐƯỜNG CONG ELLIPTIC
# ==========================================================================

# 1. Sinh khóa bí mật RSA 4096-bit mã hóa bằng AES-256
openssl genpkey -algorithm RSA -pkeyopt rsa_keygen_bits:4096 -aes-256-cbc -out root_rsa.key

# 2. Trích xuất khóa công khai từ khóa bí mật RSA
openssl pkey -in root_rsa.key -pubout -out root_rsa.pub

# 3. Liệt kê toàn bộ các đường cong Elliptic được hỗ trợ bởi OpenSSL 3.5
openssl ecparam -list_curves

# 4. Sinh khóa bí mật ECDSA trên đường cong chuẩn NIST P-384
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:secp384r1 -out ca_ecc.key

# 5. Sinh khóa bí mật Ed25519 (Kháng kênh bên, tối ưu cho TLS 1.3)
openssl genpkey -algorithm ED25519 -out server_ed25519.key

# ==========================================================================
# PHẦN 2: THỰC THI KHỞI TẠO ROOT CA VÀ INTERMEDIATE CA
# ==========================================================================
```

```
# 6. Khởi tạo chứng chỉ Root CA tự ký X.509 v3 (Thời hạn 10 năm)
openssl req -x509 -new -nodes -key root_rsa.key -sha256 -days 3650 \
  -subj "/C=VN/ST=Ho Chi Minh/O=KMA/OU=Security Division/CN=KMA National Root CA" \
  -addext "basicConstraints=critical,CA:TRUE" \
  -addext "keyUsage=critical,digitalSignature,keyCertSign,cRLSign" \
  -addext "subjectKeyIdentifier=hash" \
  -out root_ca.crt

# 7. Tạo yêu cầu ký chứng chỉ (CSR) cho Issuing Intermediate CA
openssl req -new -newkey ec -pkeyopt ec_paramgen_curve:secp384r1 -nodes \
  -keyout intermediate.key \
  -subj "/C=VN/ST=Ho Chi Minh/O=KMA/OU=PKI Center/CN=KMA Issuing Intermediate CA" \
  -out intermediate.csr

# 8. Root CA ký cấp phát chứng chỉ cho Intermediate CA (Hạn dùng 5 năm, pathlen=0)
openssl x509 -req -in intermediate.csr -CA root_ca.crt -CAkey root_rsa.key \
  -CAcreateserial -out intermediate.crt -days 1825 -sha384 \
  -extfile <(printf "basicConstraints=critical,CA:TRUE,pathlen:0\nkeyUsage=critical,digitalSignat

# ============================================================================
# PHẦN 3: CẤP PHÁT CHỨNG CHỈ WEB SERVER VỚI SAN (CA/B FORUM COMPLIANT)
# ============================================================================

# 9. Tạo CSR cho máy chủ Web với đầy đủ tên miền SAN
openssl req -new -newkey rsa:2048 -nodes -keyout web.key -out web.csr \
  -subj "/C=VN/ST=Ho Chi Minh/O=Hoc Vien Mat Ma/CN=api.kma.edu.vn"

# 10. Intermediate CA ký cấp chứng chỉ máy chủ Web (Hạn dùng 398 ngày)
openssl x509 -req -in web.csr -CA intermediate.crt -CAkey intermediate.key \
  -CAcreateserial -out web.crt -days 398 -sha256 \
  -extfile <(printf "basicConstraints=critical,CA:FALSE\nkeyUsage=digitalSignature,keyEnciphermen

# 11. Đóng gói chuỗi tin cậy đầy đủ (Full Chain)
cat web.crt intermediate.crt root_ca.crt > fullchain.pem

# ============================================================================
# PHẦN 4: KIỂM ĐỊNH, PHÂN TÍCH NHỊ PHÂN VÀ THU HỒI
# ============================================================================

# 12. Xem chi tiết văn bản đầy đủ của chứng chỉ X.509
openssl x509 -in web.crt -noout -text

# 13. Mổ xẻ cấu trúc cây dữ liệu nhị phân ASN.1 DER
openssl asn1parse -in web.crt -inform PEM

# 14. Kiểm tra xác thực đường dẫn tin cậy (Chain Validation)
openssl verify -CAfile root_ca.crt -untrusted intermediate.crt web.crt

# 15. Khởi tạo danh sách thu hồi chứng chỉ (CRL) rỗng
openssl ca -gencrl -config openssl.cnf -out crl.pem
```

```
# 16. Chuyển đổi định dạng chứng chỉ từ PEM sang nhị phân DER
openssl x509 -in web.crt -outform DER -out web.der

# 17. Đóng gói cặp khóa và chứng chỉ sang kho chứa mật khẩu PKCS#12 (.p12 / .pfx)
openssl pkcs12 -export -out bundle.pfx -inkey web.key -in web.crt -certfile intermediate.crt
```

---

## PHỤ LỤC B: BỘ CÔNG CỤ PYTHON CRYPTOGRAPHY PHÂN TÍCH & KIỂM ĐỊNH

Dưới đây là công cụ Python hoàn chỉnh dựa trên thư viện chuẩn quốc tế `cryptography` hỗ trợ học viên tự động hóa kiểm định tính hợp lệ của chứng chỉ X.509 theo các quy tắc nghiêm ngặt của CA/B Forum:

```
#!/usr/bin/env python3
# -*- coding: utf-8 -*-
'''
PKI Certificate Auditor & RFC 5280 Parser
Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512)
Tác giả: Nguyễn An Khương (Khoa KH&KT Máy tính, Trường ĐHBK Tp. HCM)
'''

import sys
import datetime
from cryptography import x509
from cryptography.hazmat.backends import default_backend
from cryptography.x509.oid import ExtensionOID, ExtendedKeyUsageOID

def audit_certificate(cert_path: str):
    print(f"[*] Tiến hành kiểm toán chứng chỉ: {cert_path}")
    with open(cert_path, "rb") as f:
        data = f.read()

    # Nạp chứng chỉ (hỗ trợ PEM hoặc DER)
    try:
        cert = x509.load_pem_x509_certificate(data, default_backend())
    except Exception:
        cert = x509.load_der_x509_certificate(data, default_backend())

    now = datetime.datetime.now(datetime.timezone.utc)

    # 1. Kiểm tra Version
    version_name = cert.version.name
    print(f" [+] Phiên bản X.509: {version_name}")
    if cert.version != x509.Version.v3:
        print("  [CẢNH BÁO] Chứng chỉ không phải X.509 v3!")

    # 2. Kiểm tra Thời gian hiệu lực
    print(f" [+] Hiệu lực từ: {cert.not_valid_before_utc} đến {cert.not_valid_after_utc}")
```

```
    if now < cert.not_valid_before_utc:
        print("  [LỖI] Chứng chỉ chưa đến thời điểm có hiệu lực!")
    elif now > cert.not_valid_after_utc:
        print("  [LỖI] Chứng chỉ ĐÃ HẾT HẠN!")
    else:
        print("  [PASS] Thời gian hiệu lực hợp lệ.")

    # 3. Kiểm tra Độ dài Serial Number (RFC 5280 giới hạn <= 20 bytes)
    serial_len = (cert.serial_number.bit_length() + 7) // 8
    print(f" [+] Serial Number: {hex(cert.serial_number)} (Độ dài: {serial_len} bytes)")
    if serial_len > 20:
        print("  [VI PHẠM RFC 5280] Serial Number vượt quá 20 bytes!")

    # 4. Kiểm tra Basic Constraints
    try:
        bc = cert.extensions.get_extension_for_oid(ExtensionOID.BASIC_CONSTRAINTS)
        print(f" [+] Basic Constraints: is_ca={bc.value.ca}, path_length={bc.value.path_length},
        if bc.value.ca and not bc.critical:
            print("  [CẢNH BÁO] Chứng chỉ CA nhưng cờ Basic Constraints không đặt CRITICAL!")
    except x509.ExtensionNotFound:
        print("  [LỖI NGHIÊM TRỌNG] Thiếu phần mở rộng Basic Constraints!")

    # 5. Kiểm tra Subject Alternative Name (SAN)
    try:
        san = cert.extensions.get_extension_for_oid(ExtensionOID.SUBJECT_ALTERNATIVE_NAME)
        names = san.value.get_values_for(x509.DNSName)
        ips = [str(ip) for ip in san.value.get_values_for(x509.IPAddress)]
        print(f" [+] SAN DNS Names: {names}")
        print(f" [+] SAN IP Addresses: {ips}")
    except x509.ExtensionNotFound:
        print("  [VI PHẠM CA/B FORUM] Thiếu phần mở rộng Subject Alternative Name (SAN)!")

    print("[*] Kiểm toán hoàn tất.")

if __name__ == "__main__":
    if len(sys.argv) < 2:
        print(f"Cách dùng: python3 {sys.argv[0]} <duong_dan_file_chung_chi>")
        sys.exit(1)
    audit_certificate(sys.argv[1])
```

---

# PHỤ LỤC C: DANH MỤC TÀI LIỆU THAM KHẢO & KHÓA HỌC QUỐC TẾ

### 1. Hệ Thống Khóa Học Quốc Tế Trực Tuyến Hàng Đầu (OpenCourseWare & Video Lectures)

- **MIT OpenCourseWare 6.857: Computer and Network Security**
  *Giảng viên:* GS. Ronald L. Rivest (Đồng tác giả RSA) và GS. Shafi Goldwasser (Giải thưởng Turing).
  *Tài nguyên:* Bài giảng lý thuyết số, định danh chứng thực số và lược đồ cam kết mật mã.

*Địa chỉ truy cập:* ocw.mit.edu/courses/6-857-computer-and-network-security-spring-2014

- **Stanford University CS 255: Introduction to Cryptography**
  *Giảng viên:* GS. Dan Boneh.
  *Nội dung:* Phân tích chuyên sâu về hệ mật khóa công khai, tính toán cặp trên đường cong elliptic (Pairing-based Crypto), thuật toán chữ ký số RSA-PSS và ECDSA.
  *Địa chỉ truy cập:* crypto.stanford.edu/~dabo/cs255/
- **UC Berkeley CS 161: Computer Security**
  *Giảng viên:* GS. Nicholas Weaver và GS. David Wagner.
  *Nội dung:* Thực hành tấn công và phòng thủ giao thức TLS/SSL, phân tích lỗ hổng CA, mô hình mối đe dọa Man-in-the-Middle và chính sách bảo mật trình duyệt.
  *Địa chỉ truy cập:* cs161.org
- **Simons Institute for the Theory of Computing (UC Berkeley):**
  *Chuyên đề: Lattices: Algorithms, Complexity, and Cryptography* & *Quantum Cryptography Program*.
  *Địa chỉ:* simons.berkeley.edu
- **IACR Real World Crypto (RWC) Symposium:**
  *Kênh tài liệu video:* Hội nghị thường niên quốc tế quy tụ các kỹ sư hàng đầu từ Google, Cloudflare, Apple về thực nghiệm triển khai TLS 1.3, PQC Migration và tấn công kênh bên vào HSM.
  *Kênh lưu trữ:* rwc.iacr.org

**2. Tiêu Chuẩn Kỹ Thuật Quốc Tế Bắt Buộc (Standards & RFCs)**

1. **IETF RFC 5280:** *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*, 2008.
2. **IETF RFC 3647:** *Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework*, 2003.
3. **IETF RFC 8555:** *Automatic Certificate Management Environment (ACME)*, 2019.
4. **IETF RFC 6960:** *X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP*, 2013.
5. **IETF RFC 6962:** *Certificate Transparency*, 2013.
6. **IETF RFC 8446:** *The Transport Layer Security (TLS) Protocol Version 1.3*, 2018.
7. **NIST FIPS 203:** *Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM)*, 2024.
8. **NIST FIPS 204:** *Module-Lattice-Based Digital Signature Standard (ML-DSA)*, 2024.
9. **NIST FIPS 205:** *Stateless Hash-Based Digital Signature Standard (SLH-DSA)*, 2024.
10. **CA/Browser Forum:** *Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates*, Version 2.0+, 2024.